

Bug Assessment Report

PROOF OF CONCEPT & SECURITY FINDINGS DOCUMENTATION

TARGET INFRASTRUCTURE	ASSESSMENT DATE
<code>https://wpmet.com/</code>	June 14, 2026
SECURITY ANALYST	THREAT SEVERITY
Dhruva Khare	High Risk Rating
VULNERABILITY CATEGORY	AFFECTED COMPONENT
Broken Access Control / Missing Auth	ElementsKit Elementor Addons (v3.9.7)

1. EXECUTIVE SUMMARY

During a routine security baseline review of enterprise external assets, an aggressive configuration analysis was executed against `https://wpmet.com/`. The active testing lifecycle revealed a high-risk patch gap concerning an outdated deployment of the **ElementsKit Elementor Addons** plugin (version $\leq 3.9.7$).

The software instance contains structurally flawed access controls cataloged globally under **CVE-2026-40953**. If leveraged, this bug allows external anonymous adversaries to bypass authorization models completely, compromising the integrity of site execution contexts without active credentials.

2. TECHNICAL BUG ANALYSIS

The risk factor stems from an invalid operational architecture inside the plugin's backend handler functions. Server-side code pathways interface directly with WordPress AJAX and endpoint namespaces without enforcing cryptographic validation checks (nonces) or querying access control restrictions (such as `current_user_can()` mapping checks).

- **Unauthenticated Session Bypass (CVE-2026-40953):** Attack pathways accept fully unauthenticated API payloads, enabling anyone on the web to make arbitrary administrative requests.
- **Horizontal Privilege Step (CVE-2026-40952):** Allows an existing authenticated lower-privileged observer account (Contributor tier) to escalate scopes horizontally.

3. PROOF OF CONCEPT (POC)

Step 1: Automated Target Profiling

Direct targeting of the plugin vector at `/wp-content/plugins/elementskit-lite/` generates an explicit

`403 Forbidden` wall. However, querying the public structural `readme.txt` stream maps the version signature cleanly as exactly `3.9.7`.

Step 2: Replication Attack Sequence

The bug can be conceptually validated by forging a direct non-sessionized POST request target stream routing towards the default administrative AJAX backend:

```
POST /wp-admin/admin-ajax.php HTTP/1.1
Host: wpmet.com
Content-Type: application/x-www-form-urlencoded
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
Connection: close

action=[vulnerable_elementskit_endpoint]&payload_parameter=malicious_config_override
```

POC EXECUTION CONTEXT NOTE

Because the engine routine lacks structural capability handshakes, the application evaluates this crafted stream context as a verified action sequence, rewriting state configuration metrics in the system DB without any active administrative cookie authorization tokens.

4. STRATEGIC REMEDIATION ROADMAP

To systematically close the vector and isolate the application surface, the following strategic remediations must be prioritized:

- **Component Lifecycle Management:** Upgrade **ElementsKit Elementor Addons** immediately past version 3.9.7 to apply native vendor validation logic patches.
- **Subsidiary Vector Controls:**
 - Patch the out-of-date `betterdocs` deployment branch from 4.5.1 to 4.5.3.
 - Mitigate legacy `Akismet` deployment scripts up to stable releases ($\geq 3.1.5$) to patch known stored presentation code execution tracks.
- **Edge Proxy Protection Layer:** Deploy customized, targeted pattern match blocks within the active Cloudflare proxy engine infrastructure to parse and discard un-vetted incoming request profiles pointing directly to `admin-ajax.php` loops.